COMPTIA SECURITY+ SY0-701 | DOMÍNIO 2 · AMEAÇAS, VULNERABILIDADES E MITIGAÇÕES (22%)

Security+ 2.4 · Cryptographic Attacks

Mestre CyberSec · **Aula 2.4 — Cryptographic Attacks** (9:31) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Downgrade attack: convence as partes a usar protocolo FRACA (SSL strip: HTTPS→HTTP); hash collision (2 textos, mesmo hash — MD5 morreu por collision); brute force da chave. Defesa: HSTS (browser NUNCA aceita downgrade pra HTTP), patch crypto, algoritmo atual (TLS 1.3).

💡 Highlights que a prova CompTIA cobra

- Downgrade: convence pra usar versão FRACA (SSL stripping)
- HSTS: o browser SE lembra que o site é HTTPS-only — mitiga o SSL strip
- Collision MD5/SHA-1: dois textos, mesmo hash — abandonados

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'forces a connection to a weaker protocol' = downgrade attack
- 'prevents downgrade to HTTP' = HSTS

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 2.4 — Cryptographic Attacks)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Ataque de Downgrade (N/A)

Um ataque que força as partes a negociar um protocolo ou conjunto de cifras mais antigo e fraco em vez da opção mais forte suportada.

⚠️ ***Armadilha CompTIA:*** *Se a questão disser 'forces a connection to a weaker protocol', marque downgrade attack; não confunda com SSL stripping, que é uma forma específica de downgrade de HTTPS para HTTP.*

• SSL Stripping (Remoção de SSL) (N/A)

Um ataque de downgrade em que o atacante intercepta tráfego HTTPS e o repassa à vítima como HTTP, removendo a criptografia TLS.

⚠️ ***Armadilha CompTIA:*** *Associe SSL stripping a downgrade HTTPS→HTTP; HSTS é a mitigação porque o navegador se lembra de exigir HTTPS.*

• Segurança Estrita de Transporte HTTP (HSTS)

Uma política de segurança web que instrui navegadores a se conectarem ao site somente via HTTPS e nunca permitirem downgrade para HTTP.

⚠️ ***Armadilha CompTIA:*** *Se a questão pergunta o que impede downgrade para HTTP/SSL strip, a resposta é HSTS.*

• Colisão de Hash (N/A)

Situação em que duas entradas diferentes produzem o mesmo valor de hash, quebrando garantias de integridade e assinatura digital.

⚠️ ***Armadilha CompTIA:*** *Duas mensagens diferentes com o mesmo hash = colisão. MD5 e SHA-1 são abandonados justamente por colisões.*

• MD5 (Message Digest 5)

Algoritmo de hash de 128 bits obsoleto e criptograficamente quebrado devido a ataques práticos de colisão.

⚠️ ***Armadilha CompTIA:*** *Se a questão citar MD5, geralmente é para indicar hash fraco/colisão; prefira SHA-256/SHA-3.*

• SHA-1 (Algoritmo de Hash Seguro 1)

Algoritmo de hash de 160 bits obsoleto e vulnerável a ataques de colisão, não mais aprovado para uso seguro.

⚠️ ***Armadilha CompTIA:*** *SHA-1 também sofreu colisão; CompTIA espera que você saiba que MD5 e SHA-1 não devem ser usados para integridade/assinaturas.*

• Ataque de Força Bruta (N/A)

Ataque que tenta sistematicamente todas as chaves, senhas ou combinações possíveis até encontrar a correta.

⚠️ ***Armadilha CompTIA:*** *Se a questão mencionar tentar todas as combinações/chaves, é brute force; defenda com chaves longas, algoritmos fortes e limitação de tentativas.*

• Segurança da Camada de Transporte 1.3 (TLS 1.3)

Versão atual do TLS que remove algoritmos legados fracos e inclui proteção contra downgrade para negociação segura.

⚠️ ***Armadilha CompTIA:*** *TLS 1.3 é a resposta atual para evitar downgrade; SSL e TLS antigos (1.0/1.1) são fracos/obsoletos.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Envenenamento de Cache DNS (DNS Cache Poisoning / Spoofing)

🏠 **Analogia Intuitiva:** Imagine a lista de contatos do seu telefone. Um golpista consegue entrar na sua casa de madrugada e alterar discretamente o número do telefone do seu banco, colocando o número da quadrilha. Quando você acorda e liga para o 'banco', quem atende é o próprio criminoso pedindo sua senha. Enquanto o seu telefone guardar essa anotação falsa na memória (cache), todas as chamadas irão para o endereço errado.

🔍 **Causa Raiz / Por que foi criado:** Servidores DNS recursivos guardam resoluções recentes em cache para economizar tempo. Se um invasor inundar o servidor com respostas falsas adivinhando o Transaction ID (TXID) antes da resposta oficial, o servidor memoriza o IP malicioso e serve esse endereço errado a todos os clientes da rede.

🛡️ **Visão do Auditor de GRC:** Auditar se os servidores DNS corporativos utilizam randomização de portas de origem (Source Port Randomization); desativar recursão aberta para a internet e exigir implementação de DNSSEC para validação criptográfica.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker inserts fraudulent IP address mappings into a DNS resolver cache, redirecting legitimate users to a phishing website'. Resposta: DNS Cache Poisoning / DNS Spoofing.

📌 Sequestro de DNS (DNS Hijacking / Rogue DNS)

🏠 **Analogia Intuitiva:** É como um invasor invadir a central de atendimento telefônico de um bairro ou reprogramar o roteador da sua casa para que, não importa para onde você tente ligar, uma telefonista falsa cúmplice da quadrilha intercepte a linha e direcione a chamada para o estabelecimento fraudulento.

🔍 **Causa Raiz / Por que foi criado:** O atacante altera diretamente a configuração dos servidores DNS nas configurações de rede da máquina vítima (modificando o arquivo hosts ou adaptador de rede), altera o roteador via senhas padrão ou sequestra a conta no registrador de domínios (Registrar Hijacking).

🛡️ **Visão do Auditor de GRC:** Bloquear alterações de adaptadores de rede e arquivos de sistema (`/etc/hosts`) via GPO/MDM; aplicar bloqueio de transferência (Registrar Lock) e MFA resistente a phishing nas contas de registro de domínios da empresa.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'malware modifies the local host network settings to point to an unauthorized DNS server controlled by the attacker'. Resposta: DNS Hijacking.

📌 Túnel DNS (DNS Tunneling - Exfiltração e C2)

🏠 **Analogia Intuitiva:** O guarda na portaria do prédio proíbe pen drives, bloqueia a internet e revoga e-mails pessoais, mas permite que funcionários enviem cartões postais simples perguntando o endereço de outras pessoas (consultas DNS na porta 53). Um espião esperto codifica arquivos confidenciais em pequenos pedaços de texto e escreve no campo de destinatário do cartão: 'senha-admin-parte1.servidor-hacker.com'. O guarda deixa passar achando que é só uma consulta inofensiva de endereço!

🔍 **Causa Raiz / Por que foi criado:** O tráfego de DNS (porta UDP 53) é vital para qualquer rede funcionar e raramente é bloqueado por firewalls simples. Invasores codificam dados arbitrários (em Base64 ou hex) dentro de consultas de subdomínio para driblar inspeções perimetrais comuns.

🛡️ **Visão do Auditor de GRC:** Implementar firewalls de próxima geração (NGFW) com inspeção profunda de pacotes (DPI) e filtros de DNS de Segurança (como Cisco Umbrella); monitorar anomalias de entropia em nomes de domínio e volumes anormais de tráfego na porta 53.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'attacker encodes stolen data within DNS query subdomains to bypass firewall egress filtering and exfiltrate data'. Resposta: DNS Tunneling.

📌 Extensões de Segurança do DNS: DNSSEC

🏠 **Analogia Intuitiva:** O DNSSEC é como colocar um lacre holográfico com assinatura reconhecida em cartório em cada página da lista telefônica. Quando o seu computador recebe a resposta com o endereço de um site, ele confere a assinatura digital matemática. Se alguém adulterou o endereço no caminho, o lacre está quebrado e a resposta é descartada na hora.

🔍 **Causa Raiz / Por que foi criado:** O protocolo DNS clássico não possui validação de autenticidade ou integridade. O DNSSEC introduz registros criptográficos (RRSIG, DNSKEY, DS) para criar uma cadeia de confiança hierárquica que atesta que o registro veio do servidor autoritativo legítimo.

🛡️ **Visão do Auditor de GRC:** Fiscalizar se as zonas de DNS públicas pertencentes à empresa estão devidamente assinadas com DNSSEC; garantir que os resolvers corporativos validem ativamente as assinaturas digitais antes de responder aos endpoints.

⚠️ **Como cai na Prova CompTIA:** Gatilho: 'technology that provides authentication and integrity for DNS responses using cryptographic digital signatures to prevent DNS poisoning'. Resposta: DNSSEC. (Pegadinha: DNSSEC NÃO criptografa o tráfego nem garante privacidade; para confidencialidade usa-se DoH ou DoT).

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Injeção de registros falsos na memória temporária do resolver DNS para desviar usuários em massa	**Envenenamento de Cache DNS (DNS Cache Poisoning)**
Modificação das configurações do adaptador de rede ou do roteador para forçar o uso de um DNS não autorizado	**Sequestro de DNS (DNS Hijacking)**
Exfiltração clandestina de dados codificados dentro de subdomínios de consultas DNS na porta 53	**Túnel DNS (DNS Tunneling)**
Assinaturas digitais de chave pública que garantem integridade e autenticidade às respostas DNS	**DNSSEC (DNS Security Extensions)**
Protocolo que cifra consultas DNS sobre HTTPS para proteger a privacidade e impedir bisbilhotagem	**DoH (DNS over HTTPS)**
Redirecionamento controlado de tráfego com destino a domínios maliciosos conhecidos para um IP seguro de auditoria	**DNS Sinkholing**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um usuário se conecta a uma rede Wi-Fi de cafeteria e digita http://portal.example.com. Um atacante intercepta a solicitação inicial, mantém o navegador comunicando-se via HTTP e faz proxy silenciosamente das solicitações para o site HTTPS real enquanto registra credenciais. Qual ataque está sendo descrito?

A) Ataque de SSL stripping/downgrade

B) Ataque de colisão de hash

C) Recuperação de chave por força bruta

D) Bypass de certificate pinning

QUESTÃO 2 · CENÁRIO DE EXAME

Após um incidente de SSL stripping em redes públicas, uma empresa quer que os navegadores nunca façam downgrade silencioso de HTTPS para HTTP para seu domínio e todos os subdomínios. Qual implantação o engenheiro de segurança deve implementar?

A) DNSSEC com validação NSEC3

B) Política HSTS com includeSubDomains e preload

C) Assinatura de código SHA-256 para todos os aplicativos

D) TLS 1.3 com perfect forward secrecy apenas

QUESTÃO 3 · CENÁRIO DE EXAME

Um pesquisador de segurança envia dois arquivos PDF diferentes que produzem o mesmo digest MD5. Um insider malicioso planeja substituir um contrato benigno por um fraudulento mantendo o checksum MD5 publicado inalterado. Qual ataque criptográfico isso ilustra?

A) Ataque de downgrade

B) Recuperação de chave por força bruta

C) Ataque de colisão de hash

D) Ataque de replay

QUESTÃO 4 · CENÁRIO DE EXAME

Um aplicativo interno legado assina atualizações de software com SHA-1. O fornecedor alerta que um atacante poderia criar uma atualização maliciosa com o mesmo valor SHA-1 de uma atualização legítima. Qual risco o fornecedor está descrevendo?

A) Falha de resistência a colisões

B) Downgrade de suíte de cifras

C) Esgotamento de chave

D) Bypass de HSTS

QUESTÃO 5 · CENÁRIO DE EXAME

Um atacante captura um arquivo criptografado protegido com uma chave DES de 56 bits. O atacante tenta sistematicamente todas as chaves possíveis até que o arquivo seja aberto. Que tipo de ataque é este?

A) Colisão de hash

B) SSL stripping

C) Ataque de downgrade

D) Ataque de força bruta

QUESTÃO 6 · CENÁRIO DE EXAME

Durante um handshake TLS, um man-in-the-middle modifica o client hello e o server hello para que a conexão use TLS 1.0 em vez de TLS 1.3. Qual ataque ocorreu?

A) Ataque de colisão de hash

B) Ataque de downgrade

C) Busca de chave por força bruta

D) Cross-site request forgery

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa habilita HSTS para app.example.com, mas não define includeSubDomains. Qual risco residual permanece?

A) Certificados MD5 no domínio principal tornam-se propensos a colisões.

B) Sessões TLS 1.3 farão fallback automaticamente para SHA-1.

C) Um subdomínio como login.example.com ainda pode sofrer downgrade na primeira visita de um usuário.

D) Ataques de força bruta contra AES-256 tornam-se viáveis.

QUESTÃO 8 · CENÁRIO DE EXAME

Um servidor web suporta TLS 1.0, TLS 1.1, TLS 1.2 e TLS 1.3. Os administradores querem reduzir a chance de clientes negociarem protocolos obsoletos durante um handshake man-in-the-middle. Qual mudança no servidor é mais apropriada?

A) Substituir a assinatura de certificado SHA-256 do servidor por MD5.

B) Habilitar HSTS apenas para HTTP na porta 80.

C) Aumentar o tamanho da chave RSA de 2048 para 3072 bits apenas.

D) Desabilitar TLS 1.0 e TLS 1.1 e exigir TLS 1.2 ou TLS 1.3.

QUESTÃO 9 · CENÁRIO DE EXAME

Um sistema de build de software verifica binários de release comparando hashes SHA-1. A liderança de segurança quer proteger contra um adversário que crie um binário malicioso com o mesmo hash do binário aprovado. Qual ação deve ser tomada primeiro?

A) Migrar as verificações de integridade de release para SHA-256 ou SHA-3.

B) Aplicar HSTS preload no servidor de build.

C) Reduzir as suítes de cifras TLS para 3DES.

D) Armazenar os hashes SHA-1 em um registro DNS TXT público.

QUESTÃO 10 · CENÁRIO DE EXAME

Uma organização usa um dispositivo embarcado que criptografa telemetria com uma chave simétrica de 64 bits. Um testador de penetração recupera a chave tentando todos os valores possíveis offline. Qual remediação reduz mais diretamente esse risco de força bruta?

A) Habilitar HSTS na interface web de gerenciamento do dispositivo.

B) Substituir o algoritmo/tamanho da chave por AES-256.

C) Trocar a integridade de mensagem de SHA-256 para MD5.

D) Exigir que usuários alterem senhas a cada 30 dias.

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Ataque de SSL stripping/downgrade

SSL stripping é um ataque de downgrade no qual o atacante impede o navegador de atualizar para HTTPS e retransmite o tráfego para o site real. Colisões de hash envolvem duas entradas com o mesmo digest, força bruta adivinha chaves, e bypass de certificate pinning é uma preocupação diferente de interceptação TLS. HSTS é a principal defesa contra SSL stripping.

Questão 2: Alternativa B — Política HSTS com includeSubDomains e preload

HSTS instrui o navegador a sempre usar HTTPS para um host e a recusar tentativas do usuário ou de atacantes de fazer downgrade para HTTP. As diretivas includeSubDomains e preload estendem essa proteção a subdomínios e ajudam antes da primeira visita. DNSSEC protege a integridade do DNS, assinatura de código protege software, e TLS 1.3 fortalece o handshake, mas por si só não impede que uma URL HTTP inicial seja interceptada.

Questão 3: Alternativa C — Ataque de colisão de hash

Uma colisão de hash ocorre quando duas entradas diferentes produzem o mesmo valor de hash. O MD5 não é mais considerado resistente a colisões, então um atacante pode substituir um arquivo fraudulento preservando o checksum. Ataques de downgrade e força bruta visam protocolos ou chaves, e um ataque de replay reutiliza dados válidos capturados.

Questão 4: Alternativa A — Falha de resistência a colisões

O SHA-1 tem fraquezas de colisão conhecidas, significando que um atacante pode gerar duas atualizações diferentes com o mesmo digest. Isso quebra a verificação de integridade baseada em SHA-1. Um downgrade de suíte de cifras visa a negociação de protocolo, esgotamento de chave não é o problema central, e HSTS está relacionado à prevenção de downgrade no transporte web.

Questão 5: Alternativa D — Ataque de força bruta

Tentar todas as chaves possíveis até encontrar a correta é um ataque de força bruta. O espaço de chave DES de 56 bits é pequeno o suficiente para ser esgotado com hardware moderno. Colisões de hash visam digests, SSL stripping faz downgrade de HTTP, e um ataque de downgrade enfraquece a negociação de protocolo.

Questão 6: Alternativa B — Ataque de downgrade

Um ataque de downgrade força duas partes a negociar um protocolo ou cifra mais antigo e fraco do que normalmente suportariam. Aqui o MITM manipula o handshake para selecionar TLS 1.0 em vez de TLS 1.3. Colisões de hash visam digests de integridade, força bruta adivinha chaves, e CSRF é um ataque de aplicação web.

Questão 7: Alternativa C — Um subdomínio como login.example.com ainda pode sofrer downgrade na primeira visita de um usuário.

Sem includeSubDomains, a política HSTS se aplica apenas a app.example.com e não aos seus subdomínios. Um atacante ainda pode fazer stripping de HTTPS em um subdomínio desprotegido, especialmente antes que o HSTS seja conhecido. Risco de certificado MD5, fallback de TLS 1.3 para SHA-1, e força bruta contra AES-256 não são consequências precisas dessa configuração de HSTS.

Questão 8: Alternativa D — Desabilitar TLS 1.0 e TLS 1.1 e exigir TLS 1.2 ou TLS 1.3.

Remover TLS 1.0 e TLS 1.1 dos protocolos suportados pelo servidor impede que clientes e atacantes negociem essas versões obsoletas. Exigir TLS 1.2 ou TLS 1.3, idealmente apenas TLS 1.3, fortalece o handshake. MD5 enfraquece assinaturas, HSTS na porta 80 está mal configurado, e uma chave RSA maior não impede downgrade de protocolo.

Questão 9: Alternativa A — Migrar as verificações de integridade de release para SHA-256 ou SHA-3.

O SHA-1 é considerado fraco para resistência a colisões, então a verificação de integridade deve migrar para um hash moderno como SHA-256 ou SHA-3. HSTS e registros DNS TXT não corrigem o risco de colisão de hash, e usar 3DES enfraquece a segurança do transporte.

Questão 10: Alternativa B — Substituir o algoritmo/tamanho da chave por AES-256.

A resistência à força bruta depende do espaço de chaves; mudar de uma chave de 64 bits para AES-256 aumenta muito o número de chaves possíveis e torna a busca exaustiva inviável. HSTS protege o transporte web, MD5 enfraquece a integridade, e expiração de senha não resolve a chave simétrica de telemetria.